

Memorándum para las partes interesadas

PARA: Gerente de TI y partes interesadas

DE: Diana Cárdenas

FECHA: 18 de mayo del 2026

ASUNTO: Hallazgos y recomendaciones de auditoría interna de TI

Estimados colegas:

Por favor revisen la siguiente información relacionada con el alcance de la auditoría interna de Botium Toys, sus objetivos, hallazgos críticos y recomendaciones.

Alcance

Los siguientes sistemas están incluidos dentro de la auditoría:

- Contabilidad
- Firewalls
- Sistema de detección de intrusiones (IDS)
- Herramienta SIEM

Estos sistemas fueron evaluados para verificar:

- Permisos actuales de usuarios
- Controles implementados actualmente
- Procedimientos y protocolos existentes

También se evaluó:

- El cumplimiento de los requisitos PCI DSS y GDPR
- El control de acceso a hardware y sistemas tecnológicos

Objetivos

Los objetivos principales de la auditoría fueron:

- Cumplir con el marco NIST CSF
- Mejorar los procesos de seguridad y cumplimiento
- Fortalecer los controles del sistema
- Aplicar el principio de mínimo privilegio
- Establecer políticas y procedimientos adecuados
- Garantizar el cumplimiento normativo

Hallazgos críticos

Se identificaron múltiples controles que deben implementarse inmediatamente para cumplir con los objetivos de auditoría, incluyendo:

- Control de mínimo privilegio y separación de funciones
- Planes de recuperación ante desastres
- Políticas de contraseñas y control de acceso
- Implementación de un sistema de gestión de contraseñas
- Cifrado para transacciones seguras
- Sistema IDS
- Copias de seguridad
- Software antivirus
- CCTV
- Cerraduras de seguridad
- Monitoreo manual de sistemas heredados
- Sistemas de detección y prevención de incendios

Además:

- Se deben desarrollar políticas para cumplir con PCI DSS y GDPR
- Se deben implementar políticas alineadas con SOC1 y SOC2 para mejorar la seguridad de los datos

Hallazgos secundarios

Los siguientes controles deberían implementarse cuando sea posible:

- Caja fuerte con control de tiempo
- Iluminación adecuada
- Gabinetes con cerradura
- Señalización del proveedor de alarmas

Resumen y recomendaciones

Se recomienda abordar prioritariamente los hallazgos relacionados con PCI DSS y GDPR, debido a que Botium Toys procesa pagos en línea de clientes internacionales.

También se recomienda:

- Aplicar el principio de mínimo privilegio
- Desarrollar políticas y procedimientos alineados con SOC1 y SOC2
- Implementar sistemas de respaldo y recuperación ante desastres
- Integrar IDS y software antivirus para mejorar la detección de amenazas

- Fortalecer la seguridad física mediante CCTV, cerraduras y controles adicionales

Estas medidas ayudarán a reducir riesgos y mejorar la postura general de seguridad de la organización.

Atentamente,

Diana Cárdenas.